

安全加固报告 FIX-02: SQL注入

修复漏洞类型: SQL注入

修复小组: 天亮了么

修复时间: 2026-08-21

对应漏洞报告: VULN-02-SQL注入

修复负责人: 蒲云楷

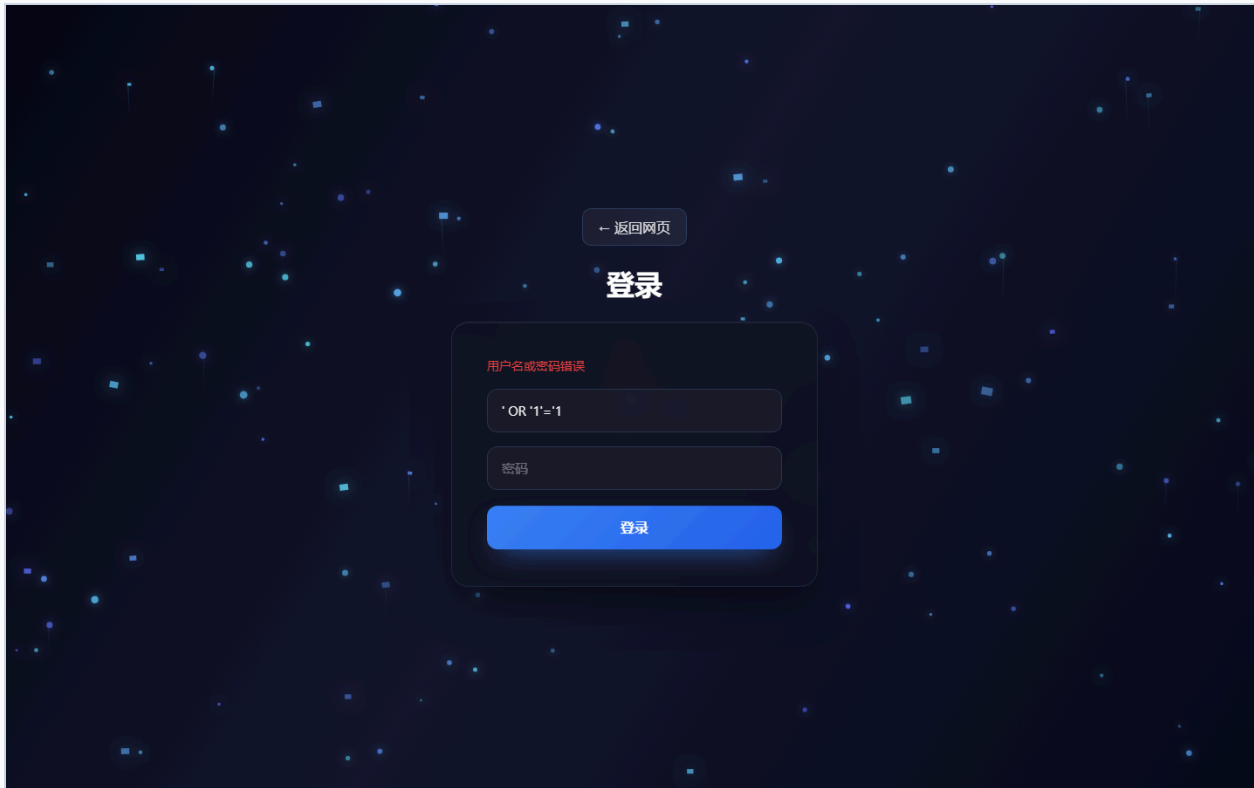
1. 基本信息

本报告按附录A记录阶段二任务2的修复和验证。

2. 漏洞复现情况

是否能按攻击方步骤复现: 修复前基线已记录; 修复后原始参数应被拦截或不产生越权效果。

复现环境: 本机 127.0.0.1:5001。



云 纯大子网盘

首页 文件 相册 传输 分享

搜索文件、图片、视频

登录 注册 纯

上传文件

全部文件

图片

视频

文档

收藏

回收站

空间使用

42.6 GB

已使用 42%，剩余空间充足

你的文件，随时可取

集中管理图片、视频、文档和学习资料，支持快速搜索、分类浏览和一键上传。

开始上传

新建文件夹

最近上传

8 个文件等待整理

我的分享

3 条链接正在生效

安全备份

今日已完成同步

最近文件

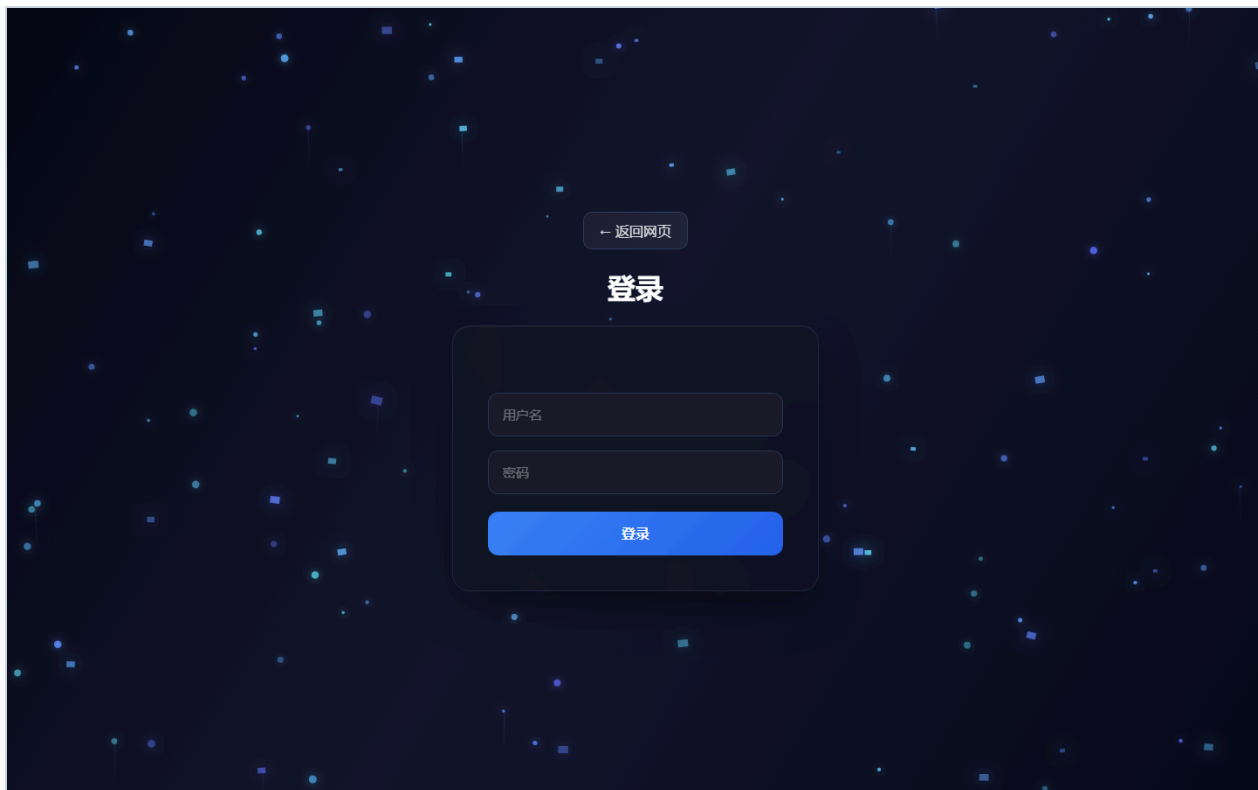
排序

筛选

名称	类型	修改时间	大小
 课程资料	文件夹	今天 16:40	--
 数据库作业说明.docx	文档	昨天 21:18	1.8 MB
 首页设计参考.png	图片	5 月 16 日	3.4 MB
 项目演示视频.mp4	视频	5 月 15 日	128 MB

Pretty-print ☐

```
{ "csrf_token": "bmZd77ZXj3Vvx7EXIZb4Ke2SKcberT8YhzcU5F1Gcotw" }
```



修复代码截图（实际源文件与行号）

任务 02 修复代码证据

gets.py:185-200

```
185     return jsonify(response), 401 if as_api else ("用户名或密码错误", 401)
186     conn = get_db_connection()
187     try:
188         with conn.cursor() as cursor:
189             cursor.execute("SELECT username, password FROM users WHERE username=%s", (username,))
190             user = cursor.fetchone()
191     finally:
192         conn.close()
193     valid = bool(user) and (
194         check_password_hash(user[1], password)
195         if user and user[1].startswith(("pbkdf2:", "scrypt:"))
196         else bool(user) and user[1] == password
197     )
198     if not valid:
199         record_login_failure(username)
200     response = {"error": "用户名或密码错误"}
```

gets.py:285-299

```
285     conn = get_db_connection()
286     try:
287         with conn.cursor() as cursor:
288             cursor.execute("SELECT 1 FROM users WHERE username=%s", (username,))
289             if cursor.fetchone():
290                 return jsonify({"error": "用户名已存在"}), 409
291             cursor.execute(
292                 "INSERT INTO users(username, password) VALUES(%s, %s)",
293                 (username, generate_password_hash(password)),
294             )
295         conn.commit()
296     finally:
297         conn.close()
298     return jsonify({"success": True}), 200
299
```

3. 根因定位

相关文件： gets.py、相关模板和前端 API 客户端。

相关函数或接口： gets.py 的 _login、_register。

问题代码/根因： 数据库查询已使用 %s 参数绑定，未发现用户输入拼接 SQL。

4. 修复措施

修改点1

修改文件： gets.py。

修改前逻辑： 缺少统一安全边界或校验。

修改后逻辑： 保留参数化查询；新增数据库接口必须禁止字符串拼接并统一错误处理。

修改点2

修改文件： 相关 HTML/CSS/前端 API（按任务适用）。

修改后逻辑： 页面和客户端与服务端安全校验保持一致，不能替代服务端校验。

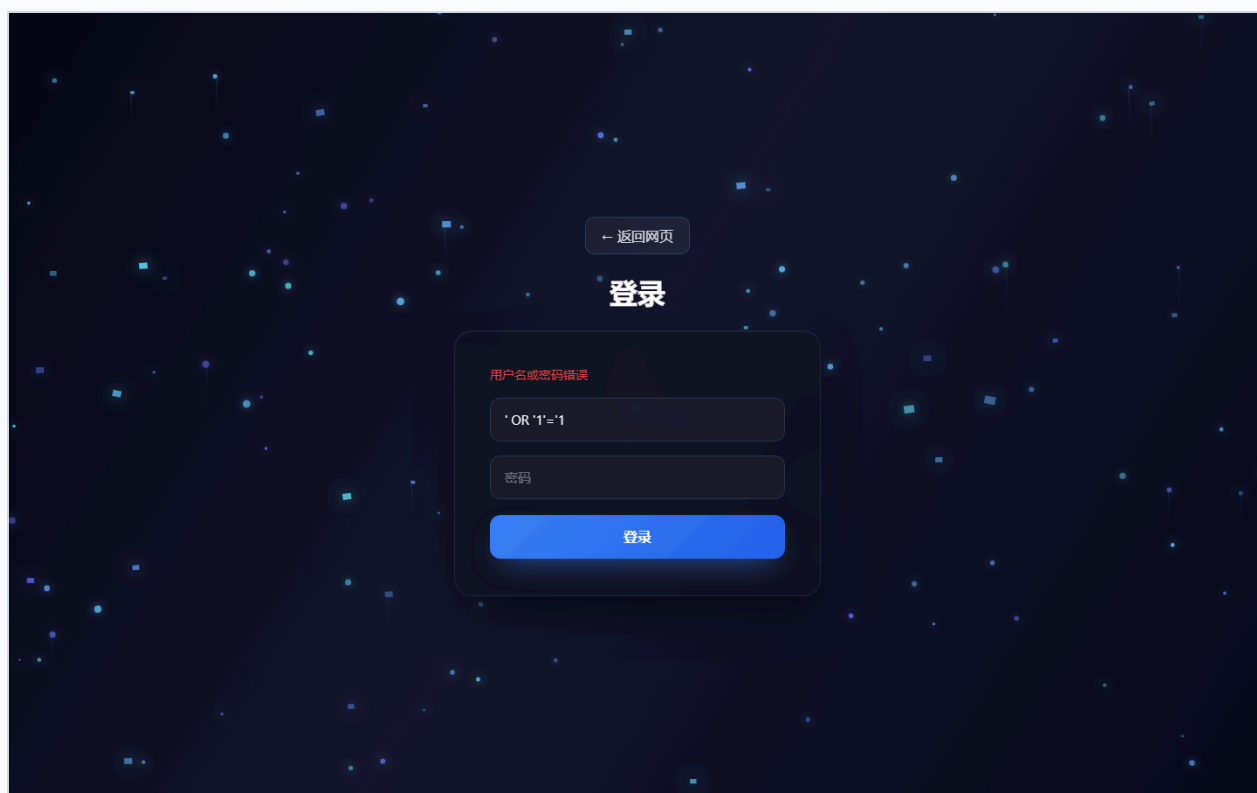
5. 修复后验证

使用攻击方原始步骤重新测试：

1. 发送原始无害测试参数。
2. 观察状态码、页面、数据、文件和日志。
3. 确认原攻击失效并保存截图。

验证结果：使用 username/password = ' OR '1'='1 进行无害登录绕过探测，返回401，无登录跳转。

原攻击是否失效：是（本机回归测试）



云 纯大子网盘

首页文件相册传输分享

搜索文件、图片、视频

登录注册纯

上传文件

全部文件

图片

视频

文档

收藏

回收站

空间使用

42.6 GB

已使用 42%，剩余空间充足

你的文件，随时可取

集中管理图片、视频、文档和学习资料，支持快速搜索、分类浏览和一键上传。

开始上传

新建文件夹

最近上传

8 个文件等待整理

我的分享

3 条链接正在生效

安全备份

今日已完成同步

最近文件

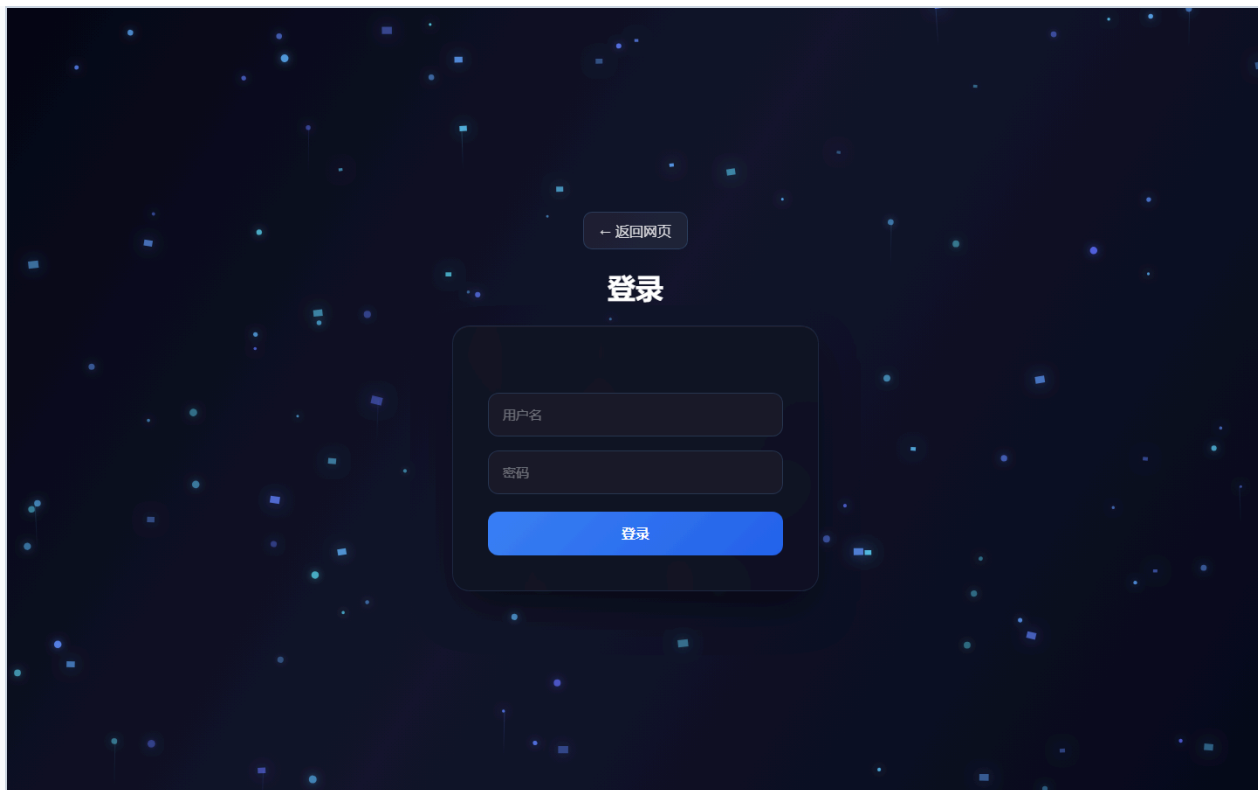
排序

筛选

名称	类型	修改时间	大小
 课程资料	文件夹	今天 16:40	--
 数据库作业说明.docx	文档	昨天 21:18	1.8 MB
 首页设计参考.png	图片	5 月 16 日	3.4 MB
 项目演示视频.mp4	视频	5 月 15 日	128 MB

Pretty-print ☐

```
{ "csrf_token": "bmZd77ZXj3Vvx7EXIZb4Ke2SKcberT8YhzcU5F1Gcotw" }
```



修复代码截图（实际源文件与行号）

任务 02 修复代码证据

gets.py:185-200

```
185     return jsonify(response), 401 if as_api else ("用户名或密码错误", 401)
186     conn = get_db_connection()
187     try:
188         with conn.cursor() as cursor:
189             cursor.execute("SELECT username, password FROM users WHERE username=%s", (username,))
190             user = cursor.fetchone()
191     finally:
192         conn.close()
193     valid = bool(user) and (
194         check_password_hash(user[1], password)
195         if user and user[1].startswith(("pbkdf2:", "scrypt:"))
196         else bool(user) and user[1] == password
197     )
198     if not valid:
199         record_login_failure(username)
200     response = {"error": "用户名或密码错误"}
```

gets.py:285-299

```
285     conn = get_db_connection()
286     try:
287         with conn.cursor() as cursor:
288             cursor.execute("SELECT 1 FROM users WHERE username=%s", (username,))
289             if cursor.fetchone():
290                 return jsonify({"error": "用户名已存在"}), 409
291             cursor.execute(
292                 "INSERT INTO users(username, password) VALUES(%s, %s)",
293                 (username, generate_password_hash(password)),
294             )
295         conn.commit()
296     finally:
297         conn.close()
298     return jsonify({"success": True}), 200
299
```

6. 额外加固

统一错误提示、输入长度限制、安全日志、Cookie 安全属性、调试模式关闭和生产密钥配置要求。

7. 仍需改进

课程组别、负责人、Git tag 等元数据需在提交前填写；HTTPS 部署时启用 Secure Cookie；Web 服务器需确认上传目录不可执行。